

SESSION 3

RAD-423 Imaging Informatics

Cybersecurity in Medical Imaging

Protecting patient data, imaging systems and radiology workflows

Course	RAD-423 Imaging Informatics
Date	Sept, 2026
Lecturer	A. A. Zubair
Suggested study time	60–90 minutes

Learning Objectives

By the end of this session, the student should be able to:

1. define cybersecurity in the healthcare and medical-imaging context;
2. explain confidentiality, integrity and availability using radiology examples;
3. identify common cyber threats that can affect PACS, RIS, EHR, workstations and imaging devices;
4. explain the purpose of authentication, least privilege, encryption, patching, network segmentation, backups and audit logs;
5. describe the human factors that contribute to cyber risk in an imaging department; and
6. outline an appropriate first response when suspicious cyber activity or an imaging-system outage is detected.

Key Concept

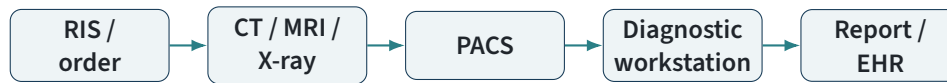
Cybersecurity in radiology is a patient-safety issue, not merely an IT issue. If an imaging system is unavailable, altered, exposed or misused, the result can affect confidentiality, diagnostic confidence, workflow and the timely treatment of patients.

1 What Cybersecurity Means in Medical Imaging

Cybersecurity is the protection of computer systems, networks and data against unauthorized access, disruption, modification or destruction. In healthcare, the protected environment includes not only office computers but also clinical systems such as PACS, RIS, EHR, diagnostic workstations, modality consoles and connected medical

devices.

Medical imaging is particularly dependent on connected systems. A typical examination may involve patient registration, order information, a modality, DICOM transmission, PACS storage, diagnostic review and report distribution. A failure at any one of these points can disrupt the whole clinical process.



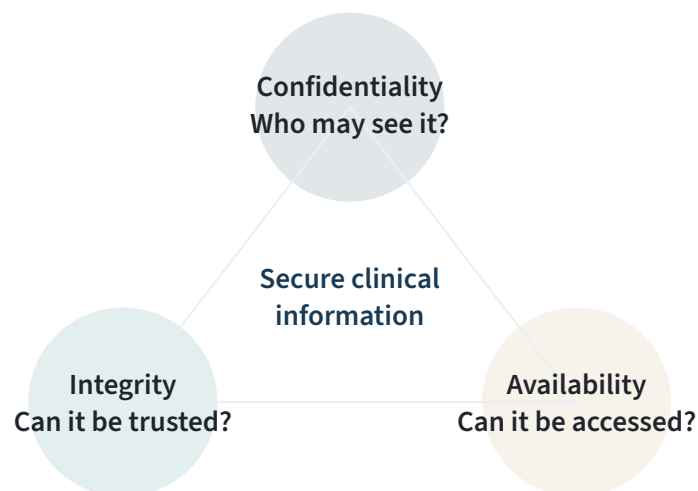
Every connection in this chain creates a legitimate pathway for information exchange. If poorly protected, the same pathway can also become a route for unauthorized access, malware propagation, data theft or service interruption.

Clinical / Practical Link

Consider an emergency CT for a patient with suspected acute stroke. If PACS is unavailable, the radiologist may be unable to retrieve the study through the normal workflow. The cybersecurity consequence is therefore not only “computer downtime”; it can delay interpretation and treatment.

2 The CIA Triad

Cybersecurity is commonly organized around three fundamental objectives: **confidentiality, integrity and availability**. Together, these form the **CIA triad**.



2.1 Confidentiality

Confidentiality means that information is accessible only to authorized people for legitimate purposes. Medical images are not anonymous pictures: they may contain patient identifiers, dates, examination details and sensitive clinical findings.

A radiographer should therefore not open a patient’s imaging record out of curiosity or because the patient is a friend, relative or public figure. Legitimate system access does not automatically mean legitimate clinical access.

2.2 Integrity

Integrity means that information remains accurate, complete and protected from unauthorized or unintended alteration. In imaging, this applies to images, reports, patient identifiers, examination metadata and system records.

An integrity failure could include a study being linked to the wrong patient, a report being changed without authorization, or imaging information being altered in a way that affects interpretation.

2.3 Availability

Availability means that authorized users can access information and services when clinically required. PACS, RIS and EHR availability is especially important in emergency care, where minutes may matter.

High-Yield

The three objectives can conflict if implemented poorly. Maximum restriction may protect confidentiality but make legitimate access difficult; maximum convenience may improve access but increase exposure. Good cybersecurity balances **confidentiality, integrity and availability** according to clinical risk.

3 Common Cybersecurity Threats

Important healthcare cyber threats include malware, ransomware, phishing, password attacks, insider threats and social engineering. In medical imaging, students should understand not only what each threat means but also how it can affect patient care and radiology workflow.

3.1 Malware

Malware is malicious software designed to compromise, disrupt, damage or misuse a computer system. Examples include viruses, worms and trojans. A compromised workstation may become an entry point into a wider network if the environment is poorly segmented.

3.2 Ransomware

Ransomware typically makes systems or data unavailable, often through encryption, and demands payment. In a hospital, the critical issue is operational disruption: PACS, RIS, EHR, laboratory systems or other services may become inaccessible.

Common Error

Do not reduce ransomware to “files being encrypted.” The clinically important consequence is loss of normal access to services and information. A hospital may still possess its data physically while being unable to use it safely or quickly enough for patient care.

3.3 Phishing and social engineering

Phishing uses deceptive messages to persuade users to reveal credentials, open malicious attachments or visit fraudulent websites. **Social engineering** is the broader manipulation of people into bypassing normal security controls.

The target is often not the scanner itself; it is the person who has access to the network, email, workstation or administrative system.

3.4 Password and credential attacks

Credential threats include password guessing, brute-force attempts, credential theft and password reuse. If the same password is reused across services, compromise of one account can increase risk elsewhere.

3.5 Insider threats

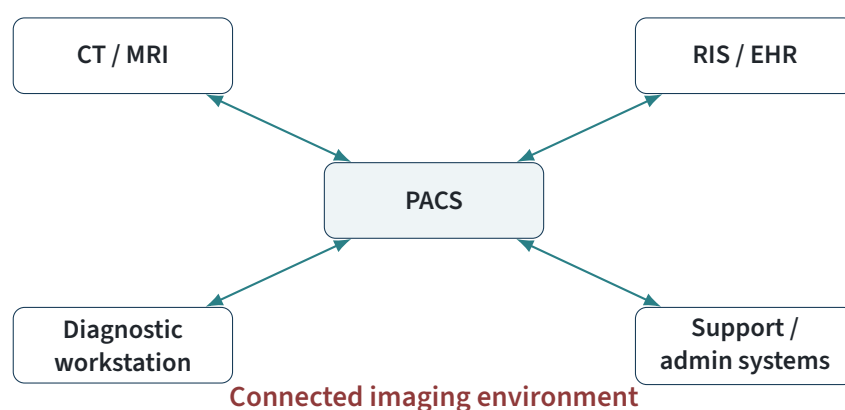
An **insider threat** involves a legitimate user who exposes, misuses or compromises information deliberately or accidentally. Examples include inappropriate record access, sharing credentials, sending data to the wrong recipient, using unauthorized storage devices or leaving a logged-in workstation unattended.

Threat	Typical mechanism	Possible imaging consequence
Malware	Malicious program on an endpoint	Workstation or network disruption
Ransomware	Data/system encryption or lockout	PACS/RIS/EHR unavailable
Phishing	Deceptive email or message	Stolen credentials or malware entry
Password attack	Guessing, theft or reuse	Unauthorized account access
Insider threat	Misuse or accidental disclosure	Privacy breach or data loss
Social engineering	Manipulation of staff	Security controls bypassed

4 Why Imaging Environments Have Special Risks

Imaging departments combine conventional IT with specialized clinical equipment. CT, MRI, X-ray and nuclear-medicine systems connect to networks for worklists, DICOM transfer, software support, storage and workflow integration. Some devices may have long service lives and may not be updated as easily as ordinary desktop computers.

A useful way to think about the risk is **connectivity plus clinical dependence**. The more systems that communicate, the more useful the workflow becomes—but the organization must control how those systems are permitted to communicate.



If one poorly protected system is compromised, an attacker may attempt to move laterally to other systems. This is one reason network segmentation and controlled access are important.

5 Protecting Imaging Systems

Protecting imaging systems requires several complementary controls, including authentication, access control, encryption, network segmentation, software updates, endpoint protection, backups and audit logs. These measures are most effective when they work together rather than as isolated controls.

5.1 Authentication and multi-factor authentication

Authentication verifies the identity of a user or system. Strong passwords are a basic control. Where technically appropriate, **multi-factor authentication (MFA)** adds another factor so that a stolen password alone is insufficient for access.

5.2 Access control and least privilege

The **principle of least privilege** means that users receive only the access required for their job. A radiographer, radiologist, PACS administrator and finance officer do not need identical permissions.

Least privilege reduces the damage that can occur if an account is misused or compromised.

5.3 Encryption

Encryption protects data by transforming it into a form that cannot be meaningfully read without the correct key. It can protect information **in transit** across networks and **at rest** in storage, depending on system design.

5.4 Network segmentation

Network segmentation separates systems into controlled network zones rather than allowing every device to communicate freely with every other device. Critical imaging systems can therefore be separated from general-purpose networks while still allowing required clinical traffic.

5.5 Patching, configuration and endpoint protection

Software updates and security patches address known vulnerabilities. Endpoint protection helps detect or block malicious activity on workstations and servers. In medical devices, updates must be coordinated carefully because safety, vendor support and clinical availability also matter.

5.6 Backups and recovery

Backups provide a recovery path when primary systems or data are damaged, deleted or encrypted. Session 2 introduced the 3-2-1 concept. For cybersecurity, the important addition is that backups must be **protected and tested**; a backup that is corrupted, inaccessible or compromised with the primary system may not support recovery.

5.7 Audit logs

Audit logs record events such as user access, administrative changes, authentication activity and system events. Logs support accountability and incident investigation, but they are useful only if relevant events are collected, protected and reviewed.

Defense in depth

No single control is enough. Strong security combines multiple layers: **identity controls + limited privileges + secure networks + maintained systems + monitoring + backups + trained users**. If one layer fails, another layer should reduce the impact.

6 Human Factors: The Radiographer's Role

Technology cannot provide complete security without appropriate user behaviour. Radiographers therefore have several practical cybersecurity responsibilities:

- never share passwords or accounts;
- lock workstations when leaving them unattended;
- verify patient identity and examination information;
- avoid unauthorized USB devices or removable media;
- avoid suspicious links and attachments;
- report suspicious activity or unexpected system behaviour promptly;
- follow institutional security policies; and
- access patient records only for legitimate professional reasons.

A suspicious email

A radiographer receives an email that appears to come from the hospital IT department. It says the PACS account will be disabled within one hour unless the user signs in through an attached link. The safe response is **not** to enter credentials through the message. The user should verify the request through the institution's approved IT/support channel and report the suspicious message according to local policy.

Clinical / Practical Link

Cybersecurity behaviour should not obstruct urgent patient care unnecessarily. When systems fail or are isolated because of a suspected incident, staff should use approved downtime procedures rather than inventing unofficial workarounds such as personal messaging applications, unapproved cloud storage or uncontrolled USB transfer.

7 A Modern Cybersecurity Lifecycle

Cybersecurity lifecycle

A useful modern way to understand cybersecurity is as a continuous lifecycle. The NIST Cybersecurity Framework 2.0 organizes cybersecurity risk management around six functions: **Govern, Identify, Protect, Detect, Respond and Recover**. Healthcare security practice similarly emphasizes controls such as multifactor authentication, encryption, network segmentation, log collection, vulnerability management and incident preparedness. The practical message is that organizations must prepare for cyber risk, protect their systems, detect abnormal activity, respond in a coordinated manner and restore safe clinical services after an incident.



For imaging staff, the practical lesson is straightforward: cybersecurity does not begin when malware is detected. It begins with governance, asset awareness, appropriate configuration, user training and preparedness.

8 What to Do When Something Looks Wrong

Radiographers are not expected to perform forensic investigation, but they should recognize abnormal events and escalate them correctly. Examples include unexplained login prompts, unexpected pop-ups, systems behaving unusually, inaccessible PACS studies, unknown USB devices, suspicious emails or a workstation suddenly displaying a ransom message.

A safe first-response pattern is:

1. **Do not improvise technically** if you are not authorized to do so.
2. **Preserve patient safety** by following approved downtime or emergency workflow procedures.
3. **Report promptly** to the appropriate IT, PACS, cybersecurity or departmental contact.
4. **Follow local instructions** on disconnecting, isolating or leaving the affected device untouched.
5. **Document relevant observations** such as time, system, error message and what happened immediately before the problem.

Common Error

Do not assume that restarting a device, deleting suspicious files or disconnecting cables is always the correct first action. During an incident, uncoordinated actions may destroy useful evidence or interfere with approved response procedures. Follow institutional policy and authorized technical guidance.

Key Takeaways

- Cybersecurity protects healthcare systems and data from unauthorized access, disruption, alteration and destruction.
- The CIA triad is confidentiality, integrity and availability.
- Common threats include malware, ransomware, phishing, password attacks, insider threats and social engineering.
- Imaging departments are vulnerable because modalities, PACS, RIS, EHR and workstations are interconnected and clinically important.
- Important controls include authentication, least privilege, encryption, segmentation, patching, endpoint protection, backups and audit logging.
- Human behaviour is a major part of security; radiographers must protect credentials, lock workstations, avoid unsafe media and report suspicious events.
- Cybersecurity is a lifecycle that includes preparation, protection, detection, response and recovery.

Key Terms

Cybersecurity

Protection of systems, networks and data against unauthorized access, disruption, modification or destruction.

Confidentiality

Restriction of information access to authorized users and purposes.

Integrity

Preservation of accurate and trustworthy information.

Availability

Reliable access to systems and information when authorized users need them.

Malware

Malicious software intended to compromise or disrupt systems.

Ransomware

Malware or an attack that denies access to systems or data and demands payment.

Phishing

Deceptive communication intended to steal information or trigger unsafe actions.

Least privilege

Giving users only the access needed for their role.

Network segmentation

Separating network zones to control communication and limit lateral movement.

Audit log

A record of system or user events used for accountability and investigation.

Self-Assessment Questions

1. Define cybersecurity and explain why it is directly relevant to patient safety in radiology.
2. Explain confidentiality, integrity and availability using one medical-imaging example for each.
3. Differentiate phishing from social engineering.
4. Explain how ransomware could disrupt an imaging department even if no image is permanently deleted.
5. What is the principle of least privilege, and why is it useful in PACS/RIS environments?
6. Explain the purpose of network segmentation in a connected imaging department.
7. List four cybersecurity responsibilities of a radiographer.
8. A PACS workstation displays an unexpected ransom message. Outline the radiographer's appropriate immediate actions.

Series Navigation

1	Data Acquisition & DICOM Foundations	4	Cloud-Based Medical Imaging
2	PACS, RIS, Storage Systems & Information Management	5	Health Data Analytics, Interoperability & Applied Practice
3	Cybersecurity in Medical Imaging — this session		

